Entra ID Identity Governance Design

Week 2 · Care Access Navigator · HealthLine Regional Medical Center (HRMC)

Board item W2 Wed: create/document the Entra ID tenant configuration available to the project, define groups and the identity governance approach

Author	Akhila Chennamaneni
Date	November 5, 2026
Version	v1.0
Tenant	Microsoft Entra ID, free tier, directory 'Default Directory' (tenant ID withheld)
Integration	OIDC app registration care-access-navigator-keycloak-broker -> Keycloak identity provider 'entra-id' in realm care-access-navigator
Evidence	EV-02..EV-06 (tenant, broker, federated user, application), EV-17 (Security defaults), 06_Evidence/07_JML_Lifecycle (JML-LOG.csv, JML-15 Entra audit log)
Data	Synthetic identities only; no ePHI

Summary: Entra ID is the workforce identity source; Keycloak is the broker and authorization layer that the applications trust. Entra decides **who** the person is and which **job role** they hold; Keycloak turns that role into application access. This document records what is built (with evidence) and the group design and governance rules the project follows.

1. Tenant configuration (as built)

Setting	Value	Evidence
Workforce accounts	Cloud-only synthetic users (for example Sathya Hasi - Physician, Tara Jones - Billing Specialist, Jeevan Smith - leaver), department and job title set	JML-LOG.csv; JML-15
Broker application	App registration care-access-navigator-keycloak-broker; user assignment required; client secret stored in the Keycloak identity provider (expiry to be recorded: CA-17)	EV-04, EV-06; SV-06
App roles	Billing, Nurse, Clinician, HR, IT-Support, Security-Analyst, Vendor (one per job function)	Realm export, IdP mappers
Role hand-off	Keycloak mappers read the 'roles' claim and grant the matching realm role, sync mode FORCE (re-applied at every sign-in, so a change in Entra wins)	Realm export
Authentication	Security defaults: **Enabled** - every user must register for MFA and is prompted when needed (always for administrators); legacy authentication blocked (exception EX-01 resolved 2026-11-05)	EV-17
Administrators	One Global Administrator (tenant owner) (privileged access matrix PA-05)	W5 PDF, PA-05

Setting	Value	Evidence
Audit log	Directory audit log, 7-day retention on the free tier; JML-cycle extract exported to the repository for permanence	JML-15

2. Group and role design

One job function = one Entra app role = one Keycloak realm role = one Keycloak group. Access is never granted to an individual outside this chain.

Entra app role	Keycloak realm role	Keycloak group	Entra group (design)	Applications
Billing	billing	Billing	CAN-Billing	Billing app
Nurse	nurse	Nurses	CAN-Nurses	EHR simulator, Patient Portal
Clinician	clinician	Clinicians	CAN-Clinicians	EHR simulator, Patient Portal
HR	hr	HR	CAN-HR	HR app
IT-Support	it-support	IT-Support	CAN-IT-Support	HR app (account support)
Security-Analyst	security-analyst	Security-Analysts	CAN-Security-Analysts	None (security events only)
Vendor	vendor	Vendors	CAN-Vendors	None by default (per request, time-boxed)

- **Built:** the seven app roles, the seven Keycloak groups and the role mappers. In Entra, app roles are assigned **directly to users** on the broker application (JML-15: assignments on 2026-10-19).
- **Designed, not built:** Entra security groups CAN-<group> that each receive one app role on the broker application, so that adding a person to a group is the only joiner step. Assigning groups to an enterprise application requires Microsoft Entra ID P1; the lab tenant is on the free tier, so direct user assignment is used and recorded here as a design gap.
- **Separation of duties:** a person holds one job-function app role at a time; privileged roles (Billing, IT-Support, Security-Analyst) get MFA through Security defaults in Entra; local Keycloak accounts in those groups get the Keycloak OTP flow (W5).

3. Identity governance approach

Process	Rule	Evidence
Joiner	Ticket (REQ-) approved by the line manager; create the Entra user with department and job title; assign exactly one app role; first sign-in creates the Keycloak copy with the mapped role	REQ-2026-0101 (Sathya Hasi, Clinician)
Mover	Change ticket (CHG-) approved by the new manager; remove the old app role before adding the new one; revoke sessions; FORCE sync removes the old Keycloak role at next sign-in	CHG-2026-0201 (Tara Jones, Nurse -> Billing)
Leaver	Termination ticket (TERM-) from HR; disable the Entra account, revoke sessions, remove the app role, then disable the Keycloak copy and remove its roles (can_iam.py leaver) - retained for audit	TERM-2026-0301 (Jeevan Smith); TC-04, TC-09
Access review	Quarterly review of every account in the realm, including Entra-federated ones (source = entra-id); flags stale, privileged-without-MFA and disabled-but-has-access accounts; reviewer decision and sign-off per account	AR-2026-Q4 (signed 2026-11-09, CA-05 verified)
Authentication	MFA for every Entra user through Security defaults; no legacy authentication	EV-17
Privileged access	Single named Global Administrator; privilege only through job-function roles; reviewed quarterly	PA-05; W5 privileged access matrix
Logging	Entra audit log exported after each JML cycle (7-day retention on the free tier); Keycloak keeps 90 days of login and admin events	JML-15; AUTH-07

4. Known gaps and next steps

Gap	Effect	Tracked as
Entra termination does not disable the Keycloak copy automatically	Leaver depends on the operator running the Keycloak step	CAN-FIND-001, CAN-CTRL-JML-002 (R02 High)
Group-based app assignment needs Entra ID P1	Roles are assigned per user instead of per group	This design (section 2)
Entra Access Reviews need an Entra ID Governance licence	Reviews run from Keycloak with can_iam.py	AR-01, CA-05
Broker client secret expiry not recorded	Federation could stop without warning	CA-17

Board item: Week 2 Wednesday is covered: tenant configuration documented with evidence (section 1), groups and roles defined (section 2), governance approach defined and exercised in the October JML cycle (section 3).